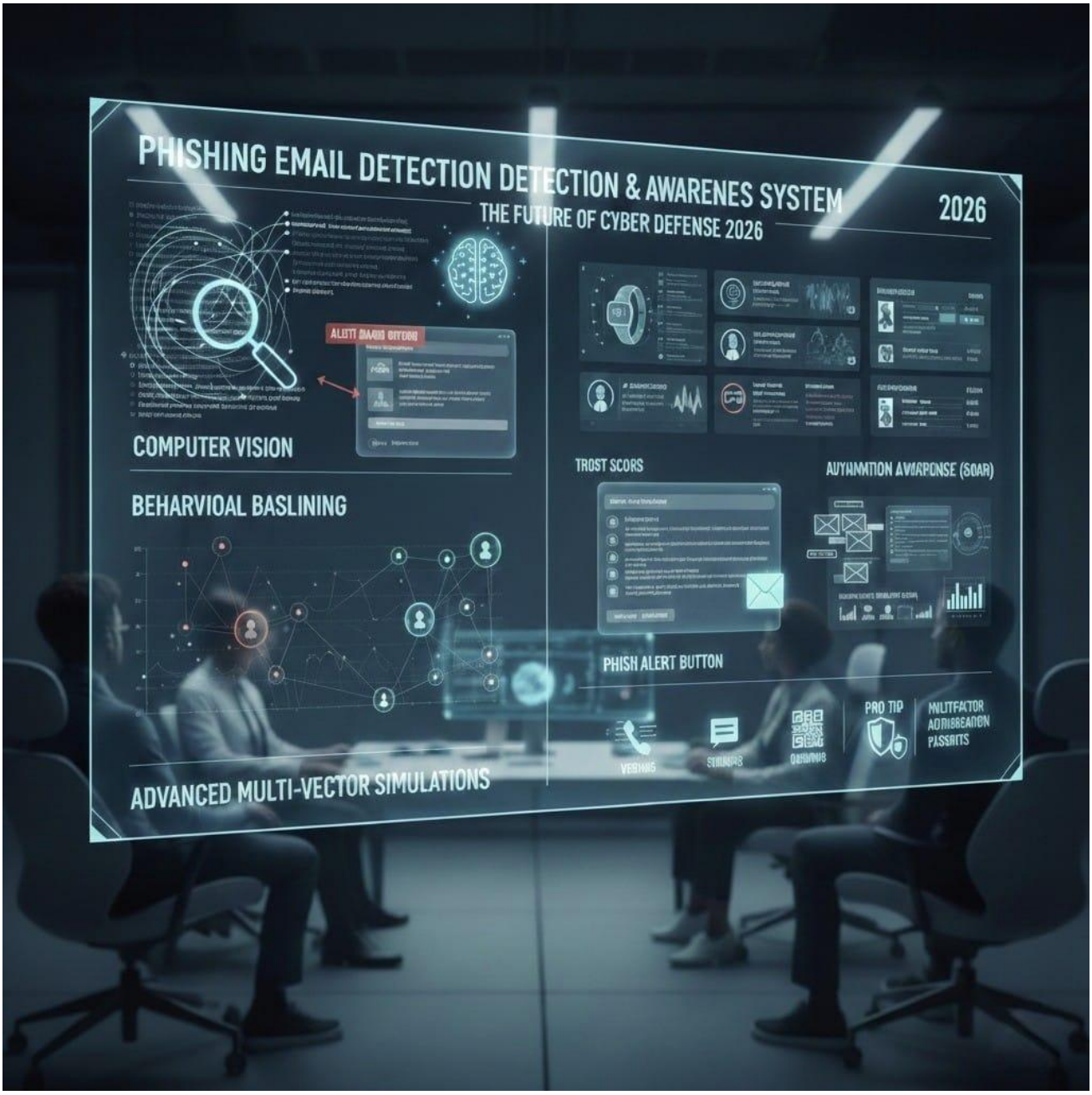
Phishing Email Detection & Awareness System



Prepared by

Harish C

Cyber security Intern

Future Interns

Introduction

Phishing is a social engineering attack in which cybercriminals send fraudulent emails to deceive individuals into revealing sensitive information such as login credentials, financial data, or personal details. These emails often impersonate trusted organizations in order to gain unauthorized access or commit fraud.

Phishing attacks are dangerous because they can lead to financial loss, identity theft, unauthorized system access, and reputational damage. Attackers exploit human trust and urgency rather than technical vulnerabilities, making awareness a critical defense mechanism.

The purpose of this report is to analyze multiple suspected phishing email samples by examining their headers, sender domains, authentication results, and embedded links. The goal is to determine whether the sender is legitimate or malicious and to classify the associated risk level.

This report also aims to identify common phishing patterns and provide awareness guidelines to help reduce cyber risk within organizations.

Methodology

In this analysis, multiple sample phishing emails were collected and examined. The complete email headers were extracted from each message and analyzed using the MXToolbox header analyzer.

The primary focus was on evaluating authentication mechanisms including SPF, DKIM, and DMARC. These protocols were reviewed to determine whether the sending IP address was authorized to send emails on behalf of the claimed domain and whether the message integrity could be verified.

In addition to authentication checks, the sender domain, Reply-To address, return path, and originating IP address were carefully examined for inconsistencies or domain mismatches. Embedded links within the email body were inspected to identify lookalike domains or suspicious external websites.

The final risk classification was determined based on a combination of authentication failures, domain impersonation indicators, urgency-based language, and potential credential harvesting attempts.

Tools Used

- MXToolbox – Used for full email header analysis, authentication verification (SPF, DKIM, DMARC), and DNS record inspection. It also helped identify sending IP addresses, return-path inconsistencies, and domain configuration issues.

- Email Client Header Extraction (Microsoft Outlook / Gmail) – Used to obtain the complete raw email headers from suspected phishing emails for detailed inspection.

Phishing Email Sample Analysis

Email Sample 1 – Microsoft Account Suspension

Dear User,

We detected unusual sign-in activity on your Microsoft account.
Your account will be suspended within 24 hours unless verified.

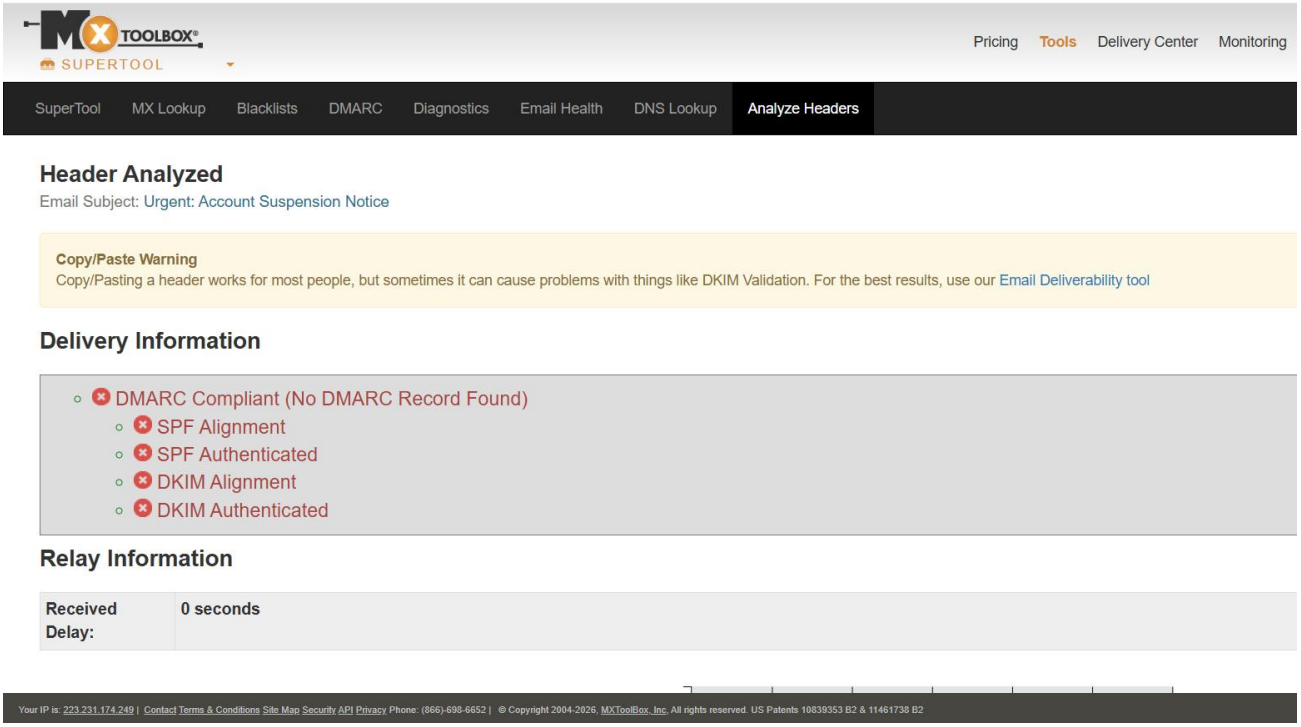
Verify immediately:
http://microsoft-account-verify-secure.com/login

Failure to act will result in permanent account closure.

Microsoft Security Team

Overview

This email claims that unusual sign-in activity was detected on the user's Microsoft account and warns that the account will be suspended within 24 hours unless immediate verification is completed. The message impersonates a security team and includes an external login link.



Header Authentication Findings

- SPF: Failed
- DKIM: Failed
- DMARC: Failed
- Sending IP: 185.203.116.24

The sending IP address is not authorized to send emails on behalf of the claimed domain. The failure of SPF, DKIM, and DMARC authentication strongly indicates domain spoofing and unauthorized sending infrastructure.

Domain and Link Analysis

The sender domain “micr0soft-support.com” uses a zero instead of the letter “o,” which is a lookalike domain tactic commonly used in phishing campaigns.

The Reply-To address does not match the From domain, suggesting redirection to an attacker-controlled mailbox.

The embedded link directs users to a non-official domain that does not belong to Microsoft.

Identified Phishing Indicators

- Multiple authentication failures
- Lookalike domain manipulation
- Reply-To domain mismatch
- Urgency-based language
- External credential harvesting link

Risk Classification

High-Risk Phishing

This email demonstrates clear signs of impersonation and credential harvesting intent.

Email Sample 2 – Bank OTP Verification

Dear Customer,

Your recent transaction was flagged as suspicious.
To avoid account freeze, confirm your OTP immediately.

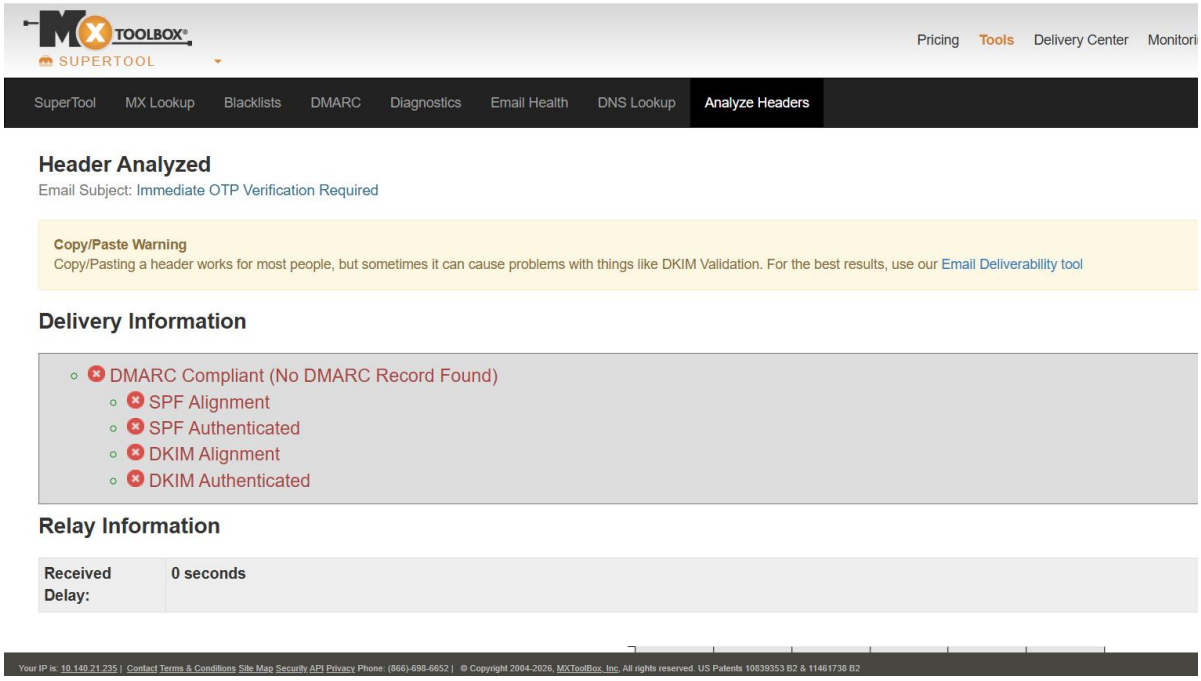
Click below:
http://secure-hdfc-authenticate.com/verify

Failure to verify within 2 hours will result in temporary suspension.

Thank you,
HDFC Bank Security

Overview

This email impersonates a banking institution and claims that a recent transaction was flagged as suspicious. The recipient is pressured to verify an OTP within two hours to prevent account suspension.



Header Authentication Findings

- SPF: Failed
- DKIM: Failed
- DMARC: Failed
- Sending IP: 103.145.67.89

The sending IP address is not authorized to send emails on behalf of the banking domain. Authentication failures confirm that the message was not sent through legitimate banking infrastructure.

Domain and Link Analysis

The sender domain “hdfc-secure-banking.net” does not match the official banking domain. The addition of terms like “secure” and “banking” is intended to create false legitimacy.

The Reply-To domain differs from the sender domain, indicating possible redirection to an attacker-controlled address.

The email contains a link designed to capture OTP credentials, which can bypass multi-factor authentication.

Identified Phishing Indicators

- Authentication failures across SPF, DKIM, and DMARC
- Lookalike banking domain
- OTP credential harvesting attempt
- Short deadline to create urgency
- Sender and Reply-To mismatch

Risk Classification

High-Risk Phishing

This email is designed to bypass two-factor authentication and gain unauthorized account access.

Email Sample 3 – Payroll Update Notification

Hello,

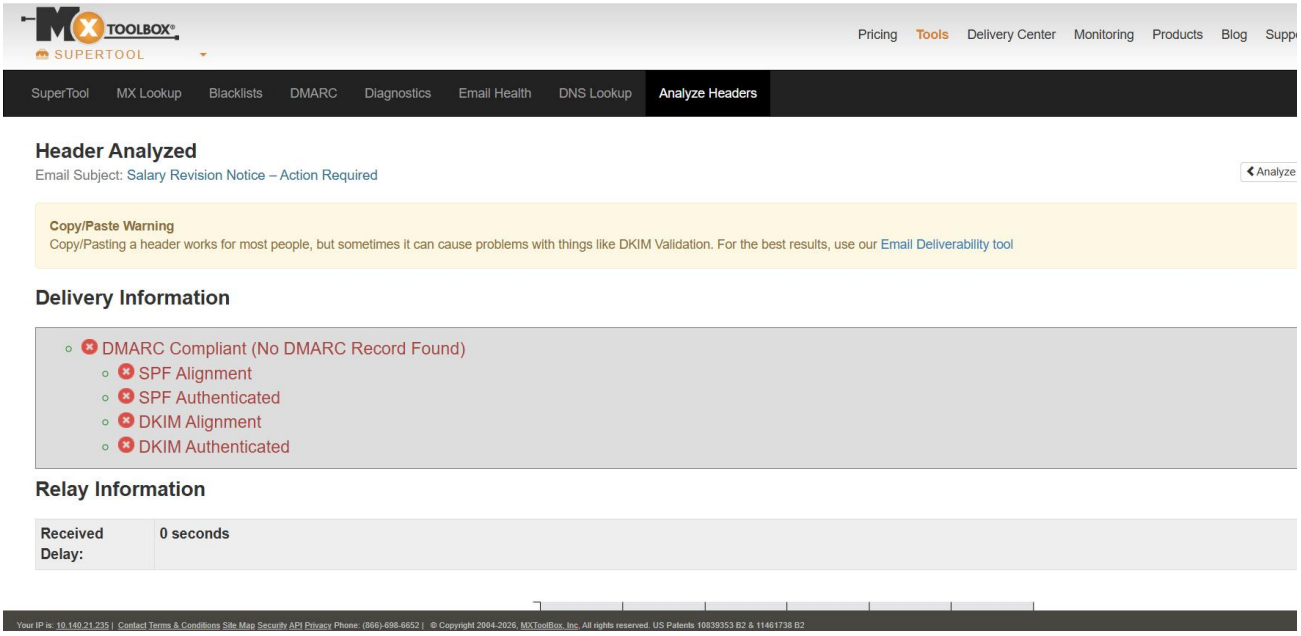
We have updated the payroll structure for this quarter.
Review your revised salary breakdown immediately.

Access document:
http://employee-salary-update-secure.com/login

Regards,
HR Team

Overview

This email impersonates the HR department and claims that the employee's salary structure has been updated. It instructs the recipient to access payroll details via an external login link.



Header Authentication Findings

- SPF: Failed
- DKIM: None
- DMARC: Failed (policy set to reject)
- Sending IP: 45.77.214.190

The sending IP address is not authorized to send emails on behalf of the organization. The absence of DKIM authentication and the DMARC failure under a reject policy strongly indicate spoofing.

Domain and Sender Analysis

The sender domain “company-payroll-update.org” does not match the official corporate domain “company.com.” This indicates impersonation.

Although the recipient address appears legitimate, the sending infrastructure is external and unauthorized.

Identified Phishing Indicators

- SPF and DMARC authentication failures
- No DKIM signature
- Lookalike payroll-related domain
- Authority impersonation (HR department)
- External login link requesting credentials

Risk Classification

High-Risk Phishing

This email attempts to exploit financial interest and organizational authority to steal employee credentials.

Summary of Findings

Sample	SPF	DKIM	DMARC	Domain Match	Risk Level
Microsoft Account Suspension	Failed	Failed	Failed	No	High
Bank OTP verfication	Failed	Failed	Failed	No	High
Payroll Update Notification	Failed	None	Failed	No	High

Prevention & Awareness Guidelines

Phishing attacks rely on human error rather than technical weaknesses. Employees must remain cautious when handling emails that request sensitive information, create urgency, or contain unexpected links or attachments. The following guidelines help reduce the risk of falling victim to phishing attacks.

Do's

- Verify the sender's full email address, not just the display name.
- Hover over links before clicking to check the real website address.
- Be cautious if the email creates urgency or demands immediate action.
- Report suspicious emails to the IT or security team immediately.
- Confirm important requests through official company websites or phone numbers.

Don't

- Do not click unknown or suspicious links.
- Do not download unexpected attachments, especially .exe or .zip files.
- Do not share passwords, OTPs, or personal information via email.
- Do not trust emails that threaten account suspension or financial loss.
- Do not assume an email is safe just because it uses a company logo or familiar name.

Recommendations

- Implement strict DMARC enforcement policies (p=reject)
- Conduct periodic phishing awareness training
- Enable advanced email filtering solutions
- Perform regular internal phishing simulations
- Monitor domain spoofing attempts using threat intelligence tools

Conclusion

The analysis of the examined email samples clearly demonstrates that phishing attacks rely heavily on human psychology rather than technical complexity. In all three cases, multiple authentication failures, domain impersonation, urgency tactics, and credential harvesting attempts were identified.

The consistent failure of SPF, DKIM, and DMARC authentication mechanisms strongly indicated sender spoofing and unauthorized email infrastructure. Additionally, lookalike domains and mismatched reply-to addresses further confirmed malicious intent.

Phishing attacks succeed when users act without verification. However, with proper awareness, careful inspection of email headers, domain validation, and timely reporting to security teams, the risk of compromise can be significantly reduced.

Ultimately, cybersecurity is not only a technical responsibility but also a human responsibility. Awareness and vigilance remain the strongest defenses against phishing attacks.